

LAB 13

Bypass de la Détection de Root

avec Objection — Android Dynamic Analysis

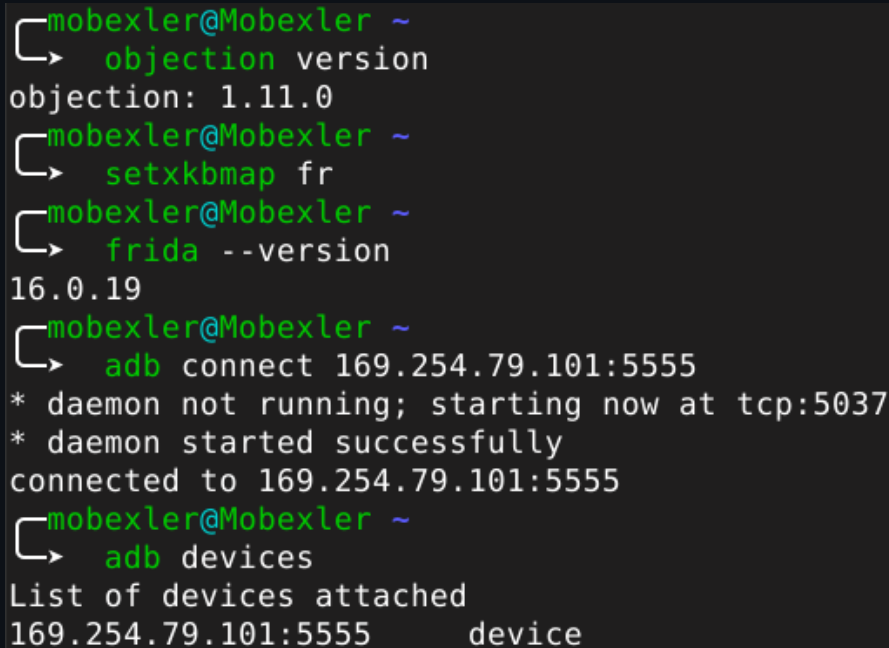
Hiba Chagdaly

Plateforme	Mobexler (Debian Bullseye)
Émulateur	Genymotion — Android 10 (API 29)
Application	OWASP UnCrackable Level 1
Outil	Objection v1.11.0 + Frida 16.0.19

Vérification de l'environnement

Avant de lancer le bypass, les versions d'Objection et de Frida sont vérifiées pour s'assurer de la compatibilité entre le client PC et le serveur Android.

```
objection version
frida --version
adb connect 169.254.79.101:5555
adb devices
```



```
mobexler@Mobexler ~
└─> objection version
objection: 1.11.0
mobexler@Mobexler ~
└─> setxkbmap fr
mobexler@Mobexler ~
└─> frida --version
16.0.19
mobexler@Mobexler ~
└─> adb connect 169.254.79.101:5555
* daemon not running; starting now at tcp:5037
* daemon started successfully
connected to 169.254.79.101:5555
mobexler@Mobexler ~
└─> adb devices
List of devices attached
169.254.79.101:5555    device
```

FIGURE 1 – Objection v1.11.0 et Frida 16.0.19 — environnement vérifié

Démarrage de frida-server et liste des applications

frida-server est lancé sur Genymotion et la liste des applications confirme la visibilité de l'émulateur depuis le PC.

```
adb shell "/data/local/tmp/frida-server &"
frida-ps -Uai | head -10
```

```
mobexler@Mobexler ~  
└─> adb shell ps | grep frida  
mobexler@Mobexler ~  
└─> adb shell "/data/local/tmp/frida-server &" 1 ↵  
^C  
mobexler@Mobexler ~  
└─> 1 ↵ 130 ↵  
  
mobexler@Mobexler ~  
└─> frida-ps -Uai | head -10 130 ↵  
PID Name Identifier  
-----  
1614 Clock com.android.deskclock  
2236 Contacts com.android.contacts  
2282 Email com.android.email  
2348 Messaging com.android.messaging  
2060 Phone com.android.dialer  
2471 Settings com.android.settings  
2514 Superuser com.genymotion.superuser  
- Amaze com.amaze.filemanager
```

FIGURE 2 – frida-server actif — liste des processus Android

Comportement sans bypass — Root détecté

Sans instrumentation, UnCrackable Level 1 détecte immédiatement l'environnement rooté et bloque l'accès à l'application.

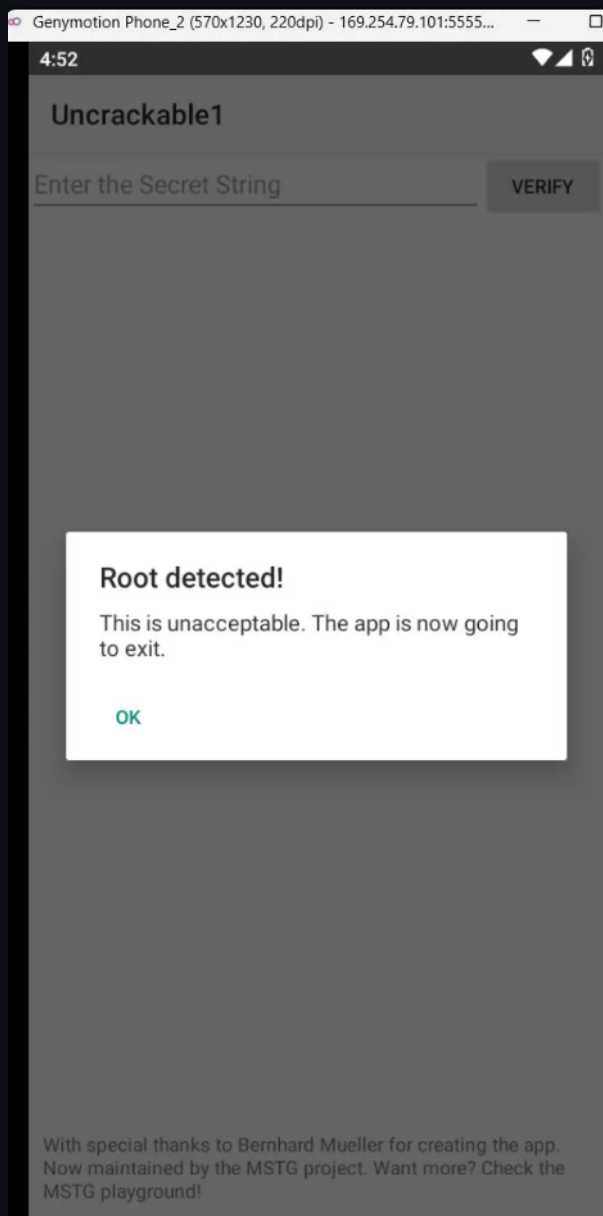


FIGURE 3 – Alerte Root detected! — application bloquée sans bypass

Lancement de la console Objection

Objection s'attache au processus UnCrackable via Frida et ouvre une console interactive. L'invite confirme la connexion à l'émulateur.

```
objection -g owasp.mstg.uncrackable1 explore
```

```
mobexler@Mobexler ~  
➔ objection -g owasp.mstg.uncrackable1 explore 130 ↵  
Using USB device `Phone`  
Agent injected and responds ok!  
  
  _ _ _ _ _  
 | . | . | . | . | . | . | . | . |  
 | _ | _ | _ | _ | _ | _ | _ | _ |  
 | _ | _ | (object)inject(ion) v1.11.0  
  
Runtime Mobile Exploration  
by: @leonjza from @sensepost  
  
[tab] for command suggestions  
owasp.mstg.uncrackable1 on (Genymotion: 10) [usb] #
```

FIGURE 4 – Console Objection — invite interactive ouverte sur Genymotion

Bypass root avec android root disable

La commande `android root disable` installe automatiquement les hooks Java nécessaires : neutralisation de `Build.TAGS`, interception de `File.exists()` et blocage de `Runtime.exec()`.

android root disable

```
[tab] for command suggestions
owasp.mstg.uncrackable1 on (Genymotion: 10) [usb] # android root disable
(agent) Registering job 897514. Type: root-detection-disable
owasp.mstg.uncrackable1 on (Genymotion: 10) [usb] #
```

FIGURE 5 – Hooks installés — job root-detection-disable enregistré

Résultat — Application accessible sans alerte

Avec les hooks actifs, UnCrackable Level 1 s'ouvre sans déclencher l'alerte root. L'interface principale est accessible.

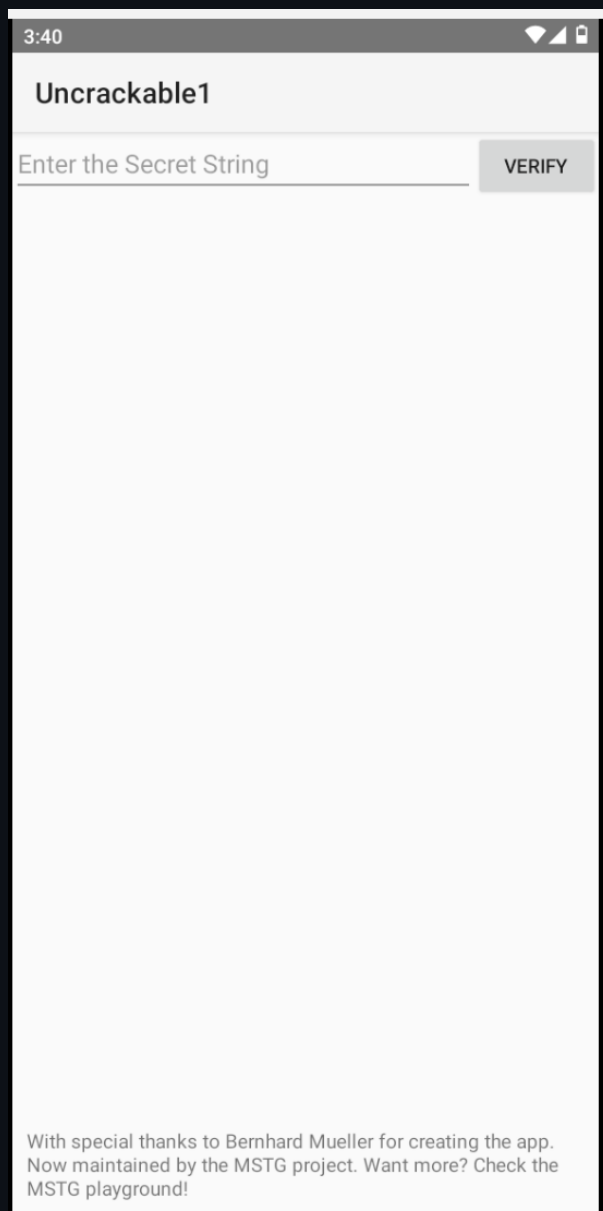


FIGURE 6 – Application ouverte sans alerte — bypass réussi

Analyse des appels natifs avec frida-trace

frida-trace révèle les appels natifs effectués par l'application. On identifie clairement les accès à `/sbin/su`, `/system/sbin/su` et `/system/bin/su` — les indicateurs de root recherchés par l'application.

```
frida-trace -U -f owasp.mstg.uncrackable1 \
-i open -i access -i stat
```

```

mobexler@Mobexler ~
└─> frida-trace -U -f owasp.mstg.uncrackable1 -i open -i access -i stat 1 ↵
Instrumenting...
open: Auto-generated handler at "/home/mobexler/__handlers__/libc.so/open.js"
access: Auto-generated handler at "/home/mobexler/__handlers__/libc.so/access.js"
stat: Auto-generated handler at "/home/mobexler/__handlers__/libc.so/stat.js"
Started tracing 3 functions. Press Ctrl+C to stop.
      /* TID 0xb69 */
866 ms open(pathname="/proc/2921/timerslack_ns", flags=0xa0241)
      /* TID 0xb6a */
883 ms open(pathname="/proc/2922/timerslack_ns", flags=0xa0241)
      /* TID 0xb6b */
940 ms open(pathname="/proc/2923/timerslack_ns", flags=0xa0241)

```

FIGURE 7 – Appels natifs tracés — accès à /sbin/su et /system/bin/su détectés

Bilan des captures

Fichier	Contenu
01-objection-version.png	Objection 1.11.0 + Frida 16.0.19
02-adb-frida-ps.png	frida-server actif + liste apps
03-root-detected-before.png	Root detected! sans bypass
04-objection-explore.png	Console Objection ouverte
05-android-root-disable.png	Commande android root disable
06-after-bypass.png	App ouverte sans alerte
07-frida-trace.png	Appels natifs open/access/stat